

Тестирование прав на методы БЛ (сценарии)

Участок: Базовые механизмы прав

В этом документе представлены сценарии тестирования прав, которые необходимо применять функциональным тестировщикам при проверке проектов. Проверка проводится на основе [опросника](#):

- Сценарий 1 необходимо проверить на страницах интерфейса, указанных в разделе опросника "Тестирование производительности - WEB".
- Сценарии 2-4 необходимо проверить на методах, созданных и измененных в рамках проекта. Они указаны в разделе "Нагрузочное тестирование".

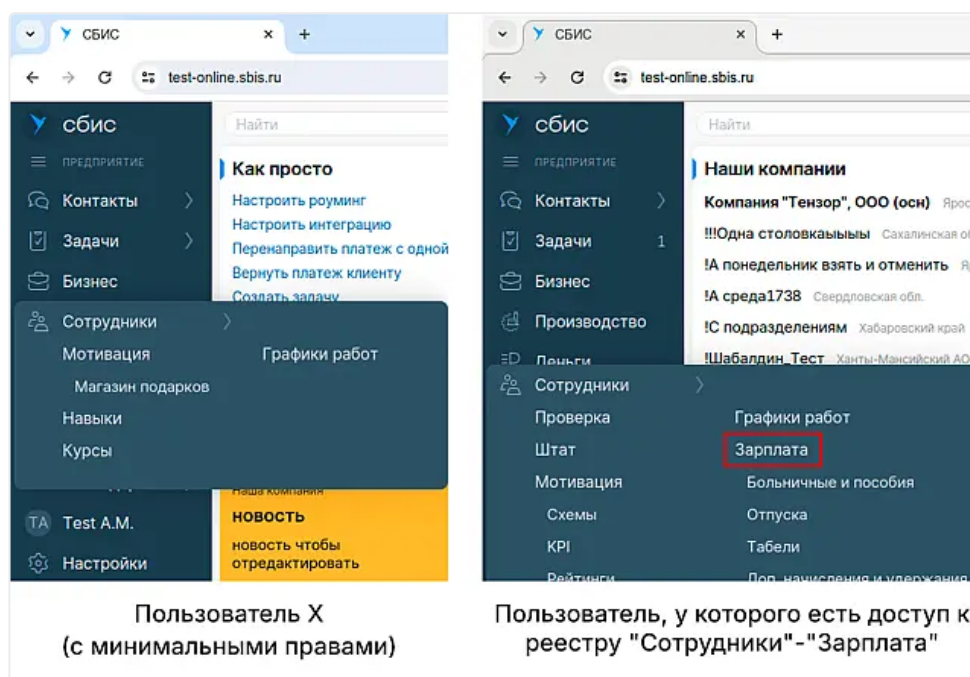
Для контроля корректности проверки отделом Тестирования безопасности, результаты тестирования прав по сценариям указанным в этом документе должны быть отражены в чек-листе.

Если прав нет на интерфейсе, то их не должно быть и на сервере

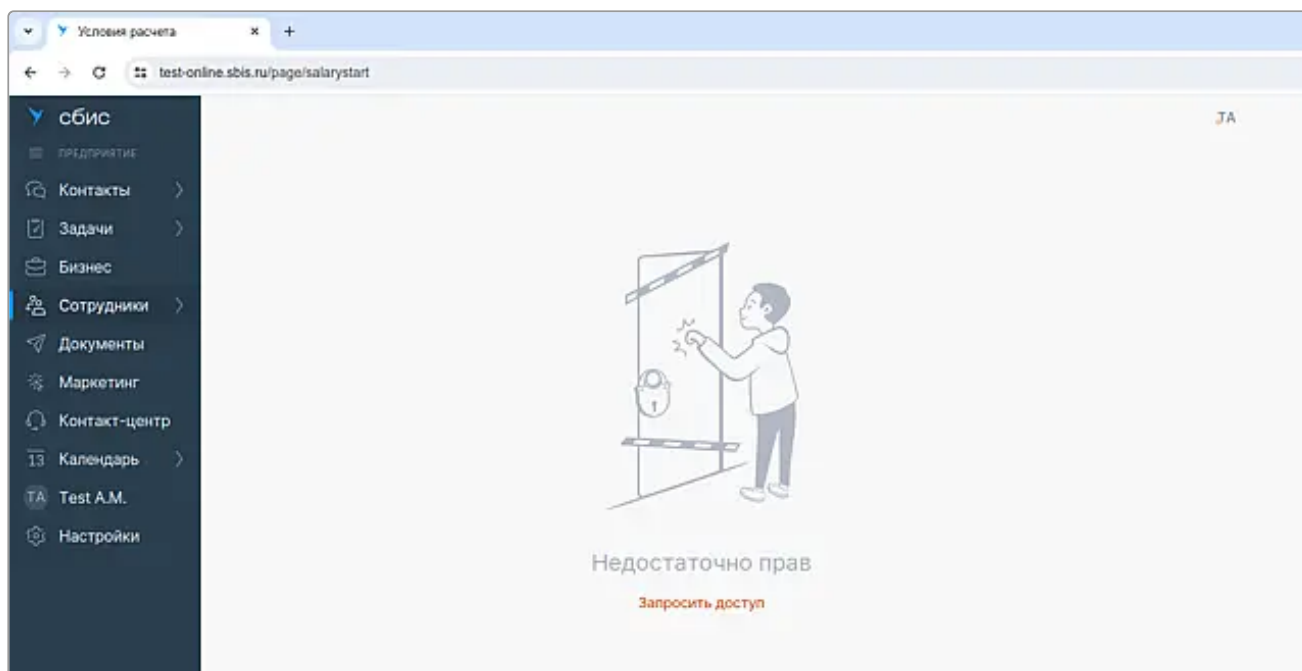
В процессе тестирования может возникнуть ситуация, когда какой-то объект (например, реестр или документ) недоступен пользователю, как предусмотрено сценарием. Однако ограничения могут быть не на сервере, а только на интерфейсе. Чтобы проверить это, нужно сделать запрос через консоль.

Пример:

Реестр "Сотрудники"- "Зарплата" недоступен через интерфейс пользователю X с минимальными правами



Реестр "Сотрудники"- "Зарплата" недоступен по прямой ссылке пользователю X с минимальными правами



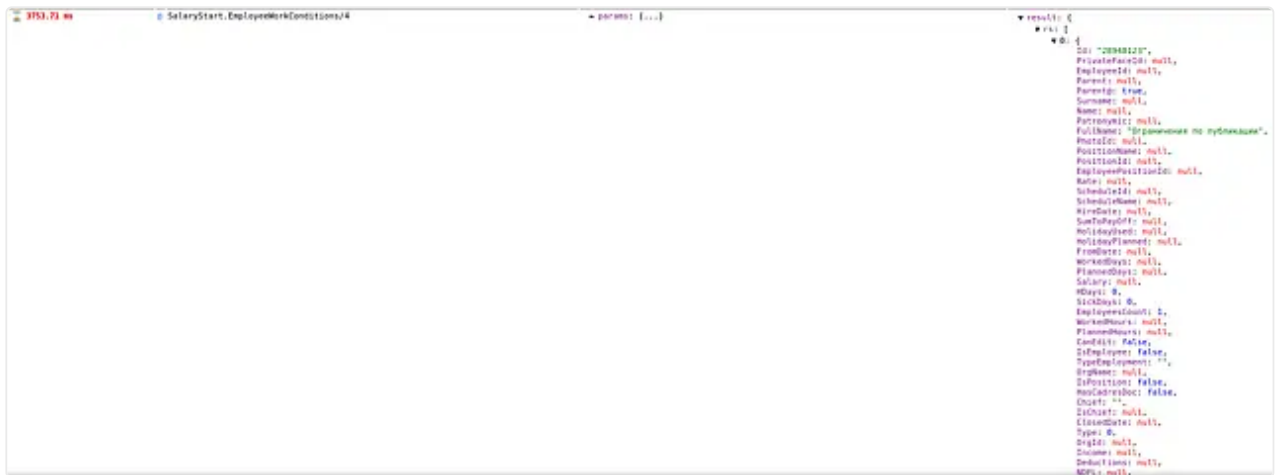
Какой метод используется?

Данные реестра возвращаются с помощью метода `SalaryStart.EmployeeWorkConditions`, это можно узнать через [Wasaby Developer Tools](#).

С даты	Ставка	График	Оклад	Оклад для разработки	Сделка	Сделка сум
			71 516 156 271 076.70	22 552 315.55	6 362 614.80	9 888.00

Понять, что именно этот метод связан с возвращаемыми данными можно взглянув на результаты запроса, они будут содержать данные, отображаемые в реестре.

▼ Пример данных



Проверка прав через консоль

Чтобы проверить, правильно ли проверяются права на сервере, нужно вызвать этот метод под сессией пользователя X (с минимальными правами) через консоль разработчика.

Чтобы сформировать код вызова метода, достаточно кликнуть по нему ПКМ в Wasaby Developer Tools. Код для вызова метода скопируется в буфер обмена.

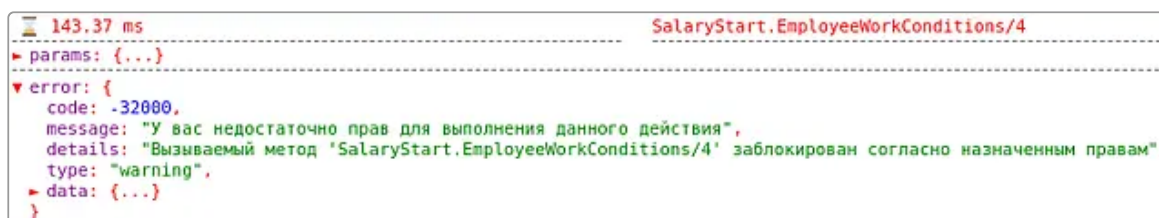
Время	Метод	Действия
4144.07 ms	@ SalaryStart.EmployeeWorkConditions/4	Добавить в ►
23.04 ms	@ ColorMark.Список/4	Облако ►
43.01 ms	@ HelpRoutePublic.ListForPage/4	Код вызова
22.46 ms	@ Notice.WriteDataListWithUA/1	Повторить запрос
		Прочее ►

Затем, под сессией пользователя X необходимо вставить сформированный код вызова в консоль разработчика в браузере и выполнить его.

▼ Пример вызова



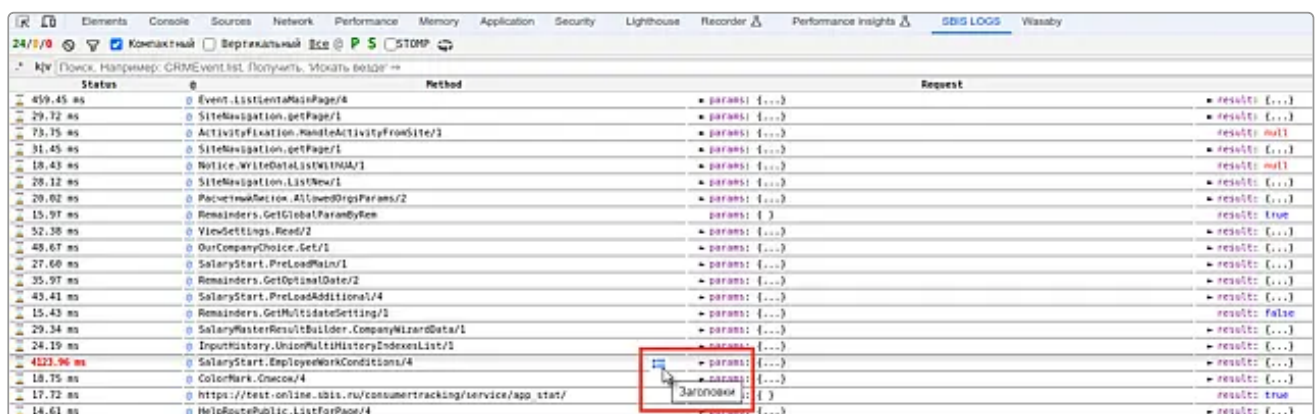
Результат выполнения метода отобразится в Wasaby Developer Tools:



Из ответа видно, что прав для выполнения метода недостаточно, права настроены корректно.

Проверка прав через Postman

Попробуем повторить этот же сценарий через Postman. Для этого, нужно узнать тело запроса и куки пользователей. Эти данные можно увидеть, нажав на кнопку "Заголовки" рядом с вызванным методом:



32/0/0 Компактный Вертикальный Все P S _STOP

Имя [Поиск, например: CRMEventList, Получить, Искать все] =>

Status	Event	Method
459.45 ms	Event.ListenMainPage/4	
29.72 ms	SiteNavigation.getPage/1	
73.75 ms	ActivityFixation.HandleActivityFromSite/3	
33.45 ms	SiteNavigation.getPage/1	
18.43 ms	Notice.WriteDataSettingsMain/3	
28.32 ms	SiteNavigation.ListNew/1	
20.82 ms	PacketMainAction.AllowDirParams/2	
15.37 ms	Reminders.GetGlobalParamByKey	
52.38 ms	ViewSettings.Read/2	
48.67 ms	OurCompany.Choice.Get/1	
27.60 ms	SalaryStart.PreloadMain/1	
35.37 ms	Reminders.GetOptimalDate/2	
43.43 ms	SalaryStart.PreloadAdditional/4	
15.43 ms	Reminders.GetMultidateSetting/1	
29.34 ms	SalaryMasterResultBuilder.CompanyMizarData/1	
24.19 ms	InputHistory.UnionMultHistoryIndexesList/3	
4127.96 ms	SalaryStart.EmployeeWorkConditions/4	
18.75 ms	ColorMark.Check/4	

X-headers - WIDOC

General

Request URL: https://test-online.sbis.ru/service/ra_version=24.6231-45

Request Method: POST

Status Code: 200

Remote Address: 10.237.176.95

Response headers

access-control-allow-credentials: true

access-control-allow-origin: https://test-online.sbis.ru

alt-csv: 03;"083"; na=86400

content-encoding: br

content-type: application/json; charset=utf-8

date: Fri, 13 Dec 2024 18:41:52 GMT

strict-transport-security: max-age=31536000;

vary: Accept-Encoding, Origin

x-application-task: 12955

x-bis: 1734086512.369

x-bis: 1734086508.264

x-bis: 4105

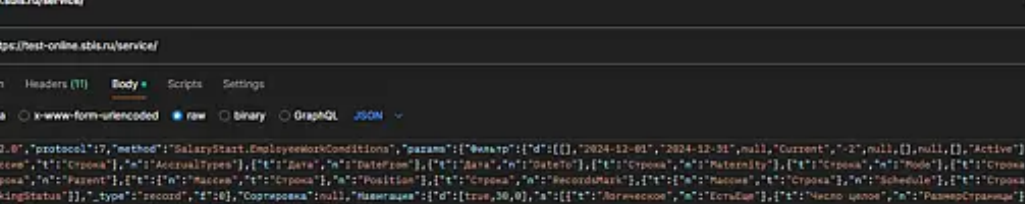
x-dispatcher: online-sbis.ru-dispatcher-759751049-k6p1 (test-online.sbis.ru)

x-bis-locale: sbis-online-ws-05_test-online-ws-frs-ws-05-test5-ABS_Person.ru

```
X-Headers: WI DOC
:ischeme: https
accept: application/json, text/javascript, */*; q=0.01
accept-encoding: gzip, deflate, br, zstd
accept-language: ru-RU;q=0.8,en-US;q=0.5,en;q=0.3
content-length: 969
content-type: application/json; charset=UTF-8
cookie: machine_name=

origin: https://test-online.sbis.ru
priority: u=1, 1
referer: https://test-online.sbis.ru/page/salarystart
sec-ch-ua: "Chromium";v="124", "Google Chrome";v="124", "Not-A.Brand";v="99"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
sec-fetch-dest: empty
sec-fetch-mode: cors
sec-fetch-site: same-origin
user-agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0.0.0 Safari/537.36
x-calledmethod: SalaryStart.EmployeeWorkConditions
x-lastmodification: 2024-12-13T134148.116563+03
x-originalmethodname: U2FsYXJ5U3RhcnQuRklwbG95ZWVkb3JrQ29uZG10aW9ucw==
x-osversion: OSType=Linux;OSVersion=CentOS 7.8.2003;IsWin11=undefined
x-requested-with: XMLHttpRequest

Request Payload
{"jsonrpc":"2.0","protocol":7,"method":"SalaryStart.EmployeeWorkConditions","params":{"@warp":{"d":[{"2024-12-01","2024-12-31",null,"Current",-2,null,[],null,{},"Active"],s":[{"t":{"n":"Массив","t":"Срока"},"n":"AccrualTypes"},{"t":{"d":{"n":"DateFrom"},"t":{"d":{"n":"DateTo"},"t":{"d":{"n":"Срока"},"n":"Maternity"},{"t":{"d":{"n":"Срока"},"n":"Mode"},{"t":{"d":{"n":"Срока"},"n":"OrgId"},{"t":{"d":{"n":"Срока"},"n":"Parent"},{"t":{"d":{"n":"Массив","t":"Срока"},"n":"Position"},{"t":{"d":{"n":"Срока"},"n":"RecordsMark"},{"t":{"d":{"n":"Массив","t":"Срока"},"n":"Schedule"},{"t":{"d":{"n":"Срока"},"n":"WorkingStatus"}},_type":"record","f":0},"Соприписка":null,"Настройка":{"d":{"true,30,0},"s":{"t":{"n":"Логическое"},"n":"Единица"},"t":{"Мно целое"},"n":"РазмерСтраницы"},{"t":{"Мно целое"},"n":"Страница"}},_type":"record","f":0},"Дополнение":{},"id":1}
```



The screenshot shows a web browser with a REST client interface. The URL bar shows `https://test-online.sbis.ru/service/`. The request is a POST to the same URL. The response is a 403 Forbidden status. The response body is in JSON format, indicating an error.

```

{
  "jsonrpc": "2.0",
  "error": {
    "code": -32000,
    "message": "У вас недостаточно прав для выполнения данного действия.",
    "details": "Выполнен метод 'SalaryStart.EmployeeWorkConditions' безпароля согласно назначенным правам",
    "type": "warning",
    "data": {
      "sessionId": "616fadd3-433a-4e2c-beeb-6c8bc76bd019",
      "error_code": 403,
      "addinfo": {
        "f": 0,

```

Используя полученные данные (необходимый адрес, куки и тело запроса) можно вызвать метод через curl:

	Роли	Зоны доступа
Сведения по зарплате Уланов П.А.		✓
Зарплата Изварин А.С.		✓
Сотрудники Дивель А.В.		✓

Одновременно в списке ролей есть "Пользователь системы".

	Роли	Зоны доступа
Секретарь	Корреспонденция, договора, совещания, наряды, приказы/извещения по сотрудникам. Просмотр проектов.	
Маркетолог	Полный доступ к реестру Маркетинг. Доступ на просмотр в CRM. Перемещение сделок по спискам, изменение тем отношений у рекламных кампаний. Просмотр отчетов о эффективности рекламных кампаний.	
Контролирующие дисциплину	Получает уведомления о нарушениях сотрудников и принимает решение о прощении или наказании за проступок	
Обслуживающий бухгалтер	Ведет бухгалтерское обслуживание в приложении Бухта по закрепленным за ним клиентам. Работает по вопросам клиентов бухгалтерского обслуживания. Не видит данные бухгалтерии своей компании.	
Супервизор соцсети	Администрирование групп соц. сети и новостей сотрудников компании	
СБИС Архив		
Техподдержка клиентов и сотрудников	Доступ в раздел "Служба поддержки". Возможность создавать и обрабатывать обращения от клиентов.	
Пользователь системы	Минимальные права пользователя, которому не назначена ни одна роль. При изменении эти настройки будут применены ко всем пользователям и ролям, права по умолчанию у которых не были переопределены.	

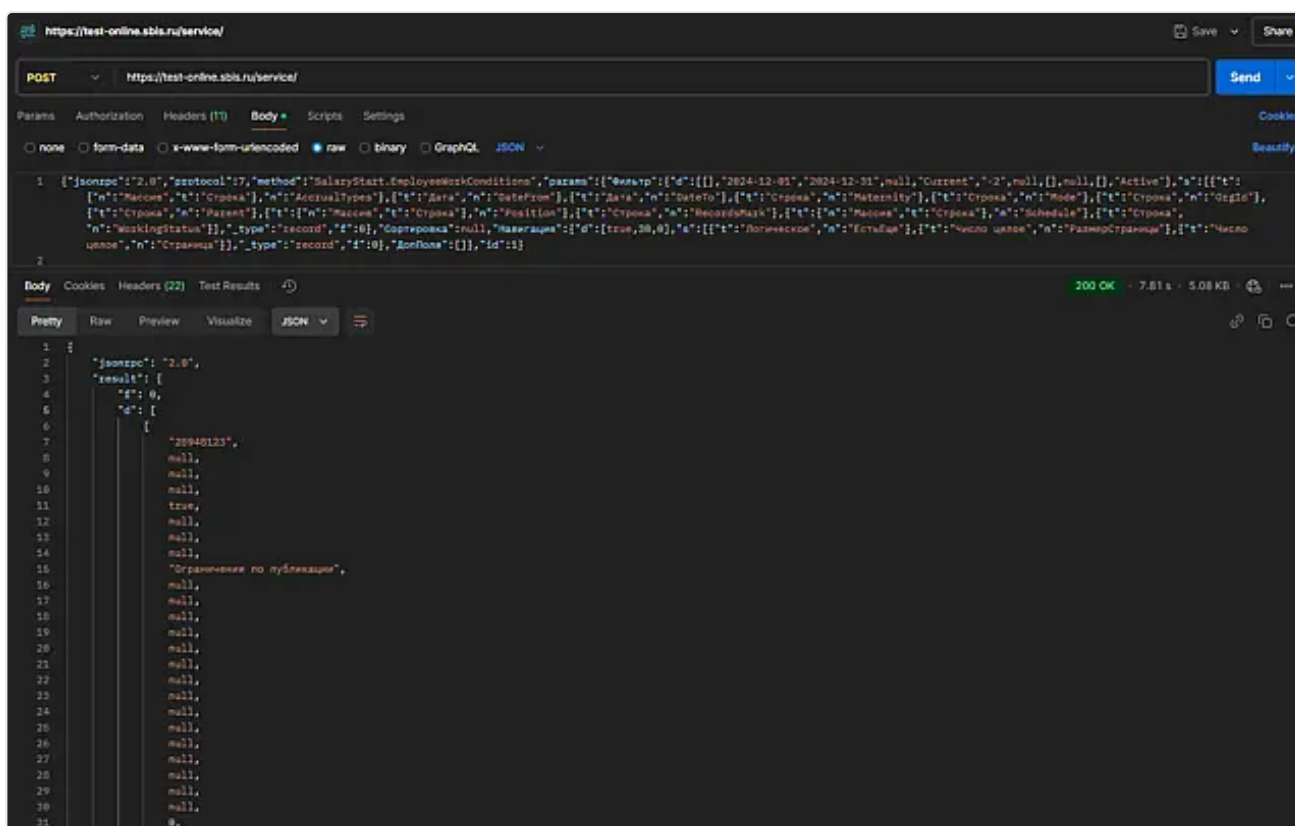
Зоны доступа пользователя X. На "зарплата" и "сведения о зарплате" стоит запрет.

▼ Сотрудники	Просмотр	с ограничениями
Выгрузка и печать	Запрет	
> Графики работ и отпусков	Просмотр	с ограничениями
Доступ и права	Запрет	
▼ Зарплата	Запрет	
> Больничные	Запрет	
> Выдача зарплаты	Запрет	
Доп. начисления и удержания	Запрет	
> Конфигурация зарплаты	Запрет	
Налоги и отчеты	Запрет	
Натуральный доход	Запрет	
> Отпуска	Запрет	
> Сведения по зарплате	Запрет	

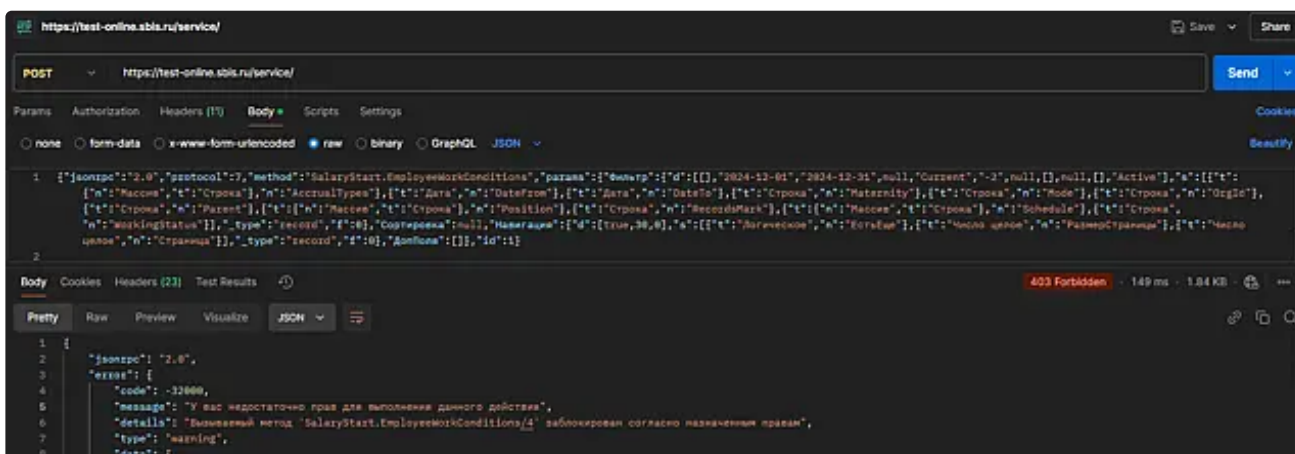
Проверяем возможность вызова

Пример ответа, если бы у пользователя было разрешение хотя бы для одной зоны доступа:

Сотрудники	Просмотр	с ограничениями
Выгрузка и печать	Запрет	
Графики работ и отпусков	Просмотр	с ограничениями
Доступ и права	Запрет	
Зарплата	Частично разрешено	
Больничные	Запрет	
Выдача зарплаты	Запрет	
Доп. начисления и удержания	Запрет	
Конфигурация зарплаты	Запрет	
Налоги и отчеты	Запрет	
Натуральный доход	Запрет	
Отпуска	Запрет	
Сведения по зарплате	Просмотр	с ограничениями



Вызываем метод из-под пользователя X (на "зарплата" и "сведения о зарплате" стоит запрет):





Если метод вернет данные, а не сообщение о недостатке прав, нужно завести ошибку.

Проверка области видимости

[Области видимости](#) позволяют настроить, по какой части компании пользователь может получать информацию. Варианты настройки:

- без ограничений - по всей компании
- по своему отделу
- только по себе.

Например, есть метод, возвращающий зарплату сотрудника по его id (@Лицо). Если у пользователя стоит ограничение только по себе на зону доступа "Зарплата", то он не сможет получить информацию ни по кому, кроме себя.

На какие методы обращать внимание: методы, которые выполняют какие-то действия по целочисленному id.

Пример

Метод **PayoutDoc.List**, который позволяет получать сведения о зарплате сотрудников.

Настраиваем зону видимости "По себе" в карточке сотрудника:

Доступ с ограничением

Вход в систему

Права

Куда имеет доступ

Найти

Все

> Контакты	Полный с настройками	с ограничениями
Новости	Просмотр и изменение	
> Задачи и проекты	Просмотр и изменение	с ограничениями
> Бизнес	Частично разрешено	
> Деньги	Запрет	
> Учет	Запрет	
> Отчетность	Частично разрешено	
▼ Сотрудники	Просмотр	с ограничениями
Выгрузка и печать	Запрет	
> Графики работ и отпусков	Просмотр	с ограничениями
Доступ и права	Запрет	
▼ Зарплата	Просмотр	с ограничениями
> Больничные	Просмотр	

Зарплата просмотр с ограничениями

Области видимости

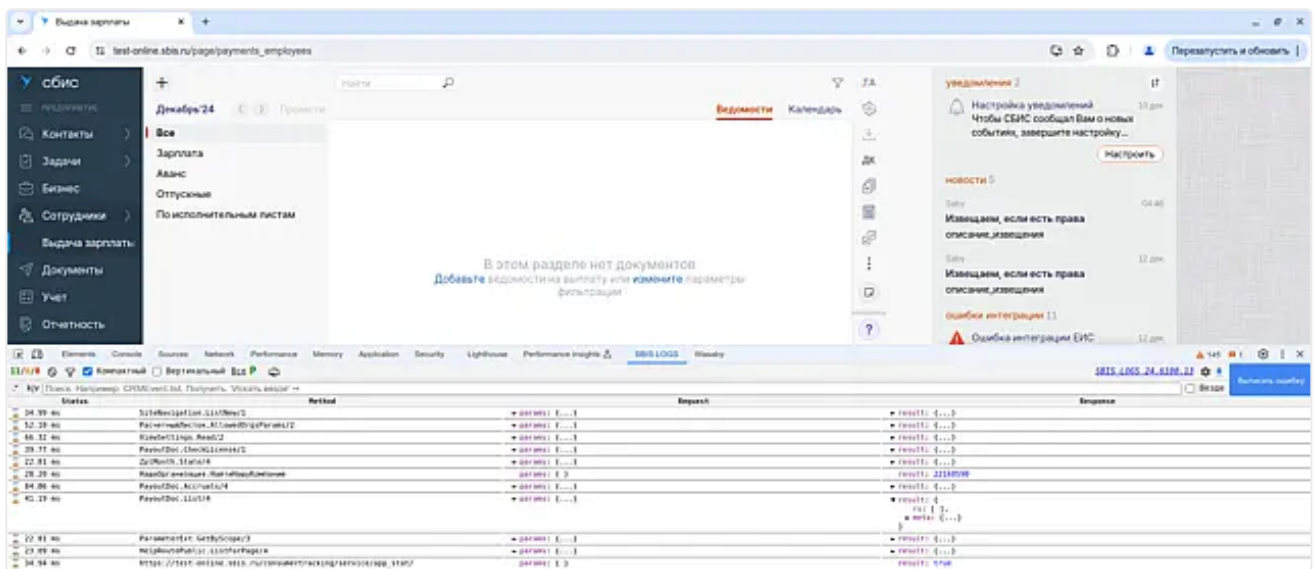
По подразделениям/сотрудникам

По себе

Что видит пользователь с зоной видимости "Свой офис":



Что видит пользователь с зоной видимости "По себе":



Выполняя тот же самый метод от имени пользователя с зоной видимости "По себе" не получаем никаких данных.

Если бы данные всё равно возвращались, необходимо было бы выписать ошибку.

Межсхемное взаимодействие

В сервисах, где база данных хранит данные из разных схем, и методы принимают ID клиента как параметр, важно проверить, что пользователи из других схем не могут изменять или просматривать данные чужих клиентов.

Пример

Метод `EmployeeContact.CompositeContacts` позволяет узнать контакты, место работы по UUID клиента.

Есть два клиента, находящиеся в разных схемах, но имеющие общую БД:

Софт Инфо Веб	Домены	Простои
ID в облаке	13020686	Номер л/с 5580804
Группа серверов	Основной сервис inside	
База данных	test-inside-pg.unix.tensor.ru:5432 test-inside.tensor.ru	
Схема в БД	_00c6ae0e	

Компания "Тензор", ООО	Домены	Простои
ID в облаке	3	Номер л/с 825049
Группа серверов	Основной сервис inside	
База данных	test-inside-pg.unix.tensor.ru:5432 test-inside.tensor.ru	
Схема в БД	_00000003	

Выполним запрос с одним и тем же ClientId от имени разных пользователей.

Запрос от имени клиента X, данные есть:

